

Internet Exposure Threat Assessment: 37-Hour Azure Honeypot Study

Oct 5, 2026 · Tim

Executive summary

An internet-exposed server is found within about an hour and then attacked at industrial scale. Over 37 hours, two cloud honeypots recorded 1,239,818 login attempts from 75 IPs, captured three malware families, and produced five detections a SOC could deploy, for about \$7 of cloud spend. No attempt reached a real account.

Metric	Result
Time to first attack (RDP)	About 1 hour after exposure
Total attempts	1,239,818 (1,234,705 RDP · 5,113 SSH) from 75 IPs in 22 countries
Peak rate	448,700 RDP attempts in one hour from a single IP, about 125 per second
Concentration	95% of attempts from 3 IPs
Failed RDP logins aimed at usernames that did not exist	99.998%
Malware captured	Panchan crypto miner (x86-64); Mirai and Bashlite IoT payloads (ARM)
Unauthorized access to real systems	None. Only the analyst's key-based logins succeeded
Total lab cost	About \$4.50 per day, about \$7 for the run

Business takeaway. Attack tooling is automated, cheap and rotates infrastructure, so blocking individual IPs fails. The controls that stopped every attempt here are low-cost: key-based authentication, no public management ports, and centralized logging with tuned alerting. Those controls cost a fraction of an average US breach, which IBM puts at \$10.22 million.

Scope and methodology

Three deliberately exposed sensors ran in Microsoft Azure from October 3 to October 5, 2026, each answering a different intelligence question. All telemetry was centralized in one Log Analytics workspace with Microsoft Sentinel as the SIEM.

Sensor	Exposure	Interaction level	Intelligence question	Telemetry
Windows 10 VM	RDP 3389, host firewall disabled	Low (real login prompt)	Who attacks, from where, with which usernames?	Security Event 4625/4624 via Azure Monitor Agent
Cowrie on Ubuntu	SSH 22	Medium (emulated shell)	What do attackers do after access?	Cowrie JSON to custom table Cowrie_CL ; session replays
Endlessh on Ubuntu	SSH 2222	None (tarpit)	How long will automated tools wait?	Syslog to Sentinel; journald on host

Enrichment. Source IPs were geolocated with a GeoIP watchlist in Sentinel, and captured files were identified by SHA-256 against public threat intelligence.

Safeguards. Real administration ran on a non-standard port, key-only, restricted by NSG to one source IP. Sensors sat in separate resource groups and virtual networks. Captured malware was never executed or moved off the quarantine host.

Key findings

F1. RDP was hammered at industrial scale, and every attempt failed

The first failed login arrived about one hour after exposure. Over 37 hours the Windows sensor logged 1,234,705 failures, and three sources made 95% of them.

Source	Network	Attempts	Pattern
61.73.165[.]91	Korea Telecom (ISP), Seoul	783,667	Flood: 448,700 in its busiest hour

Source	Network	Attempts	Pattern
144.76.103[.]122	Hetzner (hosting), Germany	285,157	Spray: 5,054 usernames, about 7 guesses each
183.80.189[.]114	Vietnam	108,540	Flood in bursts of 20,000+ per hour

The largest source sits on an ISP network, consistent with a compromised device. The second is a rented server. Locations come from KQL's built-in `geo_info_from_ip_address()`, spot-checked against `ipinfo.io`. The lab's static GeoIP list had put 4 of these top 6 sources in the wrong country, including this Hetzner server (New York) and the Vietnamese flood source (South Korea).

Failure analysis. Event 4625 records why each login failed:

Reason	Attempts	Meaning
User does not exist	1,233,774	Blind guessing. Includes ADMINISTRATOR, which Azure renames when it builds the VM
Real account, wrong password	27	Only the disabled built-ins Guest and DefaultAccount
Account disabled	1	Guest, likely a blank-password guess stopped only by the disabled state
Handshake error	2	Scanners probing RDP without completing authentication

Exports were taken minutes apart, so totals differ slightly. Event 4624 showed only the analyst's account. One bot also built usernames from the hostname (`WealthFundCord` , `Wealth` , `Fund` , `Cord`), which RDP exposes before authentication.

F2. SSH intrusions followed a full kill chain, split across specialized actors

No single actor completed the attack. Separate infrastructure handled probing, payload fetching and payload delivery.

Stage	Source	Observed behavior	Evidence
Access	Many	Dictionary guessing: <code>admin</code> with empty password (16), <code>admin/admin</code> , <code>root</code> with 1 through 1234567890 in sequence; <code>test2/test2</code>	Cowrie login events
Probe	80.94.92[.]234, 92.118.39[.]49, 80.94.92[.]55	Hourly shifts, one login per minute; CPU, GPU, uptime and login-history checks; an <code>echo "xxxxxx"</code> script to detect emulation	Same SHA-256 written 199 times across 9 IPs
Fetch	130.12.180[.]51	One-line dropper: <code>auth_ok</code> beacon, staging in <code>/tmp</code> , attacker-supplied SSH key and no-prompt config, <code>scp</code> of a script from 217.60.102[.]5 with <code>wget / curl</code> fallback, then self-cleanup	Full session replay; key fingerprint captured
Deliver	177.74.153[.]10	30.3 MB ELF named <code>sshd</code> placed in a hidden folder, launched with <code>nohup</code> against about 50 target IPs	Binary quarantined; hash matches Panchan

Why it matters. The probe fleet rotated IPs inside one address block, so IP blocking alone would have failed. Tool fingerprints (file hashes, SSH client banners, behavior) were stable and are the better detection anchor.

Night shift: IoT botnet payloads. From 21:09 UTC on October 4, a hosting server in Amsterdam (94.154.43[.]69, Storm Industries) uploaded eight 32-bit ARM ELF binaries and two loader scripts into Cowrie, then repeated the delivery hours later. [ThreatFox](#) lists one binary as a Mirai payload and one script as a Bashlite payload. ARM builds target routers and cameras; the bot pushed them to an x86 server without checking. A separate 196 KB partial upload from 120.48.125[.]245 carries an ELF header pointing to a 30.3 MB file, consistent with an interrupted Panchan transfer.

Fleet growth. The 109.160.32.x fleet reached nine IPs, seven stopping at exactly 500 attempts. The honeypot-test script arrived from nine IPs across three /24 blocks (80.94.92.x, 92.118.39.x, 2.57.122.x).

F3. The tarpit showed modern tools fail fast

Endlesssh held 101 connections for 1.2 hours in total; the longest single holds were 1,061 and 1,031 seconds. Most connections ended at 20 to 40 seconds, which indicates built-in timeouts in current scanners. Volume was also limited by port 2222's lower scan rate and a mid-study IP change.

MITRE ATT&CK mapping

Observed behavior maps to 13 techniques across 8 tactics.

Tactic	Technique	Observed evidence
Reconnaissance	T1595.001 Active Scanning: Scanning IP Blocks	Port probes under 1 second before return visits; Nmap and ZGrab banners
Reconnaissance	T1592 Gather Victim Host Information	Username generated from the hostname exposed by RDP
Credential Access	T1110.001 Brute Force: Password Guessing	783,667 RDP failures from one IP in about 3 hours
Credential Access	T1110.003 Brute Force: Password Spraying	5,054 usernames at about 7 guesses each from one Hetzner server
Initial Access	T1078.001 Valid Accounts: Default Accounts	Guest, DefaultAccount, <code>admin</code> with empty password, <code>test2/test2</code>
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	One-line bash droppers and loader scripts
Discovery	T1082 System Information Discovery	<code>uname -a</code> , CPU, GPU and uptime checks
Defense Evasion	T1497.001 Virtualization/Sandbox Evasion: System Checks	<code>echo "xxxxxx"</code> emulation test from 9 IPs

Tactic	Technique	Observed evidence
Command and Control	T1105 Ingress Tool Transfer	<code>scp</code> from 217.60.102[.]5; SFTP uploads of Panchan and Mirai/Bashlite payloads
Defense Evasion	T1036.005 Masquerading: Match Legitimate Name	Malware named <code>sshd</code>
Defense Evasion	T1564.001 Hide Artifacts: Hidden Files and Directories	Dot-prefixed folders in <code>/tmp</code>
Defense Evasion	T1070.004 Indicator Removal: File Deletion	<code>rm -rf sshcfg key.ppk out_sh</code>
Impact	T1496 Resource Hijacking	Panchan crypto-miner payload; GPU reconnaissance

Indicators of compromise

Indicators are defanged for safe sharing. Several IPs are likely compromised third-party hosts, so treat them as low-confidence block candidates; hashes and the staging host are high-confidence.

Type	Indicator	Context	Confidence
SHA-256	<code>94f2e4d8d4436874785cd14e6e6d403507b8750852f7f2040352069a75da4c00</code>	Panchan miner, ELF x86-64, 30,304,472 bytes, named <code>sshd</code>	High
SHA-256	<code>941efe52eb858311653bf2c1e855555cf735896d500f11ea90aaf7e93d1faa3f</code>	ARM ELF; ThreatFox: Mirai payload	High
SHA-256	<code>586960df8bf559ffbba600f11917a99baed4a875cb7faa5eabc060bcde67277b</code>	Loader script; ThreatFox: Bashlite payload	High
SHA-256	<code>af77b643964afd794460d28ab8a11b0ec8790cd5463abfde126613a4f3bccd32</code>	Emulation-check script used by the probe fleet	High (tool fingerprint)
SHA-256	<code>43728fbfb98bb39ff61a2db0fc2905bd6937997062b05b9ab8b186fdee18c09a</code>	Attacker-supplied ED25519 private key	High

Type	Indicator	Context	Confidence
SSH key fingerprint	SHA256:0/at8341SoPpKvTPvMsJSgjQm30md9VTS2it25sY0vg (comment dlr@sftp)	Credential the dropper uses to reach its staging server	High
URL	hxxps://217.60.102[.]5/sh	Second-stage script; host in a Turkish data center (AS48678)	High
IPv4	217.60.102[.]5	Payload staging server, user dlr	High
IPv4	94.154.43[.]69	Delivered Mirai/Bashlite payloads (hosting, Amsterdam)	Medium
IPv4	177.74.153[.]10	Delivered Panchan binary	Medium
IPv4	130.12.180[.]51	Ran dropper one-liner	Medium
IPv4	61.73.165[.]91	783,667-attempt RDP flood (Korea Telecom; likely compromised device)	Low to medium
SSH client banner	SSH-2.0-Go	Dominant brute-force tool	Low alone, useful in correlation

Recommended next step: report the staging server and payload URL to AbuseIPDB and URLhaus so other defenders can block them.

Detection engineering

Five detections were derived from observed behavior. Together they cover every attacker type seen, with no overlapping alerts.

Detection	Logic	Catches
RDP brute force	10+ Event 4625 from one IP in 5 minutes	Floods and grinders (e.g. 783,667-attempt source)
Low-and-slow brute force (v2)	20+ failures across 3+ separate hours at under 2 per minute	Slow attackers that never trip the rate rule; validated on 6 sources at 0.08 to 1.74 per minute
Password spraying	20+ usernames from one IP in 10 minutes, under 3 guesses each	The 5,054-username Hetzner spray
Brute force then success	Any 4624 from an IP with 10+ 4625s in the prior hour	The one alert that signals compromise (none occurred)
Linux dropper pattern	Download tool, world-writable path and execute in one command	Fetch and deliver stages in F2

```
// RDP brute force: Sentinel scheduled analytics rule, run every 5 min
SecurityEvent
| where EventID == 4625
| summarize Attempts = count(), Accounts = dcount(Account),
    FirstSeen = min(TimeGenerated), LastSeen = max(TimeGenerated)
    by IPAddress, bin(TimeGenerated, 5m)
| where Attempts >= 10
```

```
// Brute force followed by a successful logon (high severity)
let suspects = SecurityEvent
| where TimeGenerated > ago(1h) and EventID == 4625
| summarize Fails = count() by IPAddress
| where Fails >= 10;
SecurityEvent
| where TimeGenerated > ago(1h) and EventID == 4624
| join kind=inner suspects on IPAddress
| project TimeGenerated, Account, IPAddress, Fails
```

Design note. Detections key on behavior and tool fingerprints, not individual IPs, because the probe fleet rotated addresses on a schedule.

Tuning example. Version 1 of the low-and-slow rule (50+ attempts over 2+ hours) missed a source making one guess every 12 minutes (38 attempts in 7.5 hours) and duplicated alerts for fast attackers. Version 2 lowered the volume floor, required activity in 3+ separate hours and capped the rate below 2 per minute. It caught all six slow sources and dropped every fast one.

```
// Low-and-slow brute force v2: run hourly, look back 24h
SecurityEvent
| where TimeGenerated > ago(24h) and EventID == 4625
| where IpAddress !in ("", "-")
| summarize Attempts = count(), Accounts = dcount(Account),
              HoursWithActivity = dcount(bin(TimeGenerated, 1h)),
              FirstSeen = min(TimeGenerated), LastSeen = max(TimeGenerated) by
IpAddress
| extend PerMinute = round(Attempts / max_of((LastSeen - FirstSeen) / 1m,
1.0), 2)
| where Attempts >= 20 and HoursWithActivity >= 3 and PerMinute < 2
```

Cost and risk analysis

Attackers operate at a cost of dollars per day, while a single successful breach costs a US organization millions. The economic case for baseline controls and automated detection is therefore overwhelming; the expensive line item is analyst time, which is why tuned automation matters.

Defender cost of this study

Item	Cost per day
Windows VM (D2as_v7)	\$2.90
OS disk	\$0.60
Public IP	\$0.12
Ubuntu sensor VM	\$0.50
Log Analytics and Sentinel	Negligible at this volume (free trial)
Total	About \$4.50 per day; about \$7 for the 37-hour run

Attacker cost, from published research

Capability	Reported price
Generic botnet rental	About \$5 per day (Trend Micro via The Register)
Botnet rental, monthly	\$30 to \$4,800 by size (Kaspersky via CyberSecureFox)
Botnet from leaked source code	Free to \$50 (same research)
Compromised hosts doing the work	\$0 to the operator; victims carry the cost

Cost of failure

Measure	Value
Global average breach cost, 2025	\$4.44M (IBM)
US average breach cost, 2025	\$10.22M (Bluefin summary of IBM)
Average saving with extensive security AI and automation	\$1.9M per breach (Northdoor summary of IBM)

The people cost. The BLS median for information security analysts is \$124,910, about \$60 an hour ([Qualora](#)). Covering 168 hours a week takes roughly 4 to 5 analysts, about \$500K to \$625K a year in salary alone (estimate). That is why the detections above are tuned to cut noise: every false positive spends paid analyst minutes, while every attack in this study cost the attacker almost nothing.

Value statement. Controls that blocked 100% of attempts here (key-only SSH, no exposed management ports, logging with tuned alerts) cost little beyond configuration time. Against a \$10.22M average US breach, preventing a single incident repays years of that effort.

Recommendations

The top three controls are low-cost and would have neutralized every attack observed. Priorities are ordered by risk reduced per unit of effort.

Priority	Control	Risk addressed	Effort	Direct cost
1	Remove public RDP and SSH; use Azure Bastion, a VPN, or just-in-time access	All F1 and F2 entry points	Low	Low (Bastion is billed hourly)
2	Key-only SSH; disable password authentication	Dictionary and default-credential guessing	Low	None
3	Strong unique passwords, MFA, and account lockout for any remaining password logins	RDP brute force	Low	None to low
4	Deploy the three detections above as Sentinel analytics rules	Undetected compromise; slow response	Medium	Analyst time to tune
5	Feed high-confidence IOCs (hashes, staging host) into block lists and EDR	Known payload and staging infrastructure	Low	None
6	File-integrity and process monitoring for binaries named like system services in temp paths	Masquerading malware such as the fake <code>sshd</code>	Medium	Included in most EDR
7	Egress filtering from servers to the internet	Dropper fetching second-stage payloads	Medium	None

Item 7 deserves emphasis: the dropper in F2 failed only because the sensor could not reach its staging server. Default-deny outbound traffic from servers would break the same chain on a real host.

Limitations

Results describe opportunistic, automated attacks against fresh cloud IPs over about two days; they do not represent targeted attacks.

- **Short window.** About 37 hours captures automated background noise, not longer campaigns or human-operated follow-up.
- **Collection gap.** The Ubuntu sensor was offline for part of October 4 and returned on a new public IP, which reset attacker discovery and reduced tarpit volume.
- **Geolocation.** The lab's static GeoIP list put 4 of the top 6 attackers in the wrong country, left a Google Cloud server blank, and gave some IPs two locations. It was replaced with KQL's built-in `geo_info_from_ip_address()` and spot-checked against `ipinfo.io`. A location shows where an attack was launched from, not who ran it.
- **Emulation bias.** Some tools detect Cowrie and abort, as the probe fleet appears to have done, so post-access behavior is under-sampled.
- **Attribution.** Malware identification rests on hash matching to public listings (ThreatFox and published honeypot reports); no dynamic analysis was performed, by design.
- **SSH visibility.** Real SSH logins were confirmed on the host because the Syslog rule did not yet collect auth logs.
- **Third-party prices.** Attacker cost figures come from published vendor research spanning 2020 to 2026 and are indicative, not current market quotes.

Analyst competencies demonstrated

This project exercised the core SOC analyst workflow end to end, from building telemetry to delivering business-ready recommendations.

Competency	Evidence in this report
Cloud security engineering	Built isolated Azure sensors with NSG rules, key-only admin access and segmented networks
SIEM and log pipeline	Onboarded Windows events, custom JSON and Syslog into Sentinel via Azure Monitor Agent and data collection rules
Query and analytics (KQL)	Wrote queries for geolocation enrichment, session timing, string extraction and cross-source correlation
Threat hunting	Pivoted from a repeated hash to a rotating IP fleet; reconstructed a dropper from a session replay

Competency	Evidence in this report
Malware triage	Identified a payload safely by hash and file metadata without execution
Threat intelligence	Mapped behavior to MITRE ATT&CK; produced a defanged, confidence-rated IOC set; reported infrastructure
Detection engineering	Designed and tuned three behavior-based detections with documented thresholds
Risk and cost communication	Quantified defender versus attacker economics and prioritized controls by effort and cost

Resume-ready summary: Built a multi-sensor Azure honeypot with Microsoft Sentinel; captured and identified a live crypto-mining botnet payload, analyzed 1.24 million attack attempts, mapped activity to 13 MITRE ATT&CK techniques, authored five tuned detection rules, and presented a cost-risk analysis with prioritized controls.

Appendix: queries and sources

Failed RDP logins by source, with location:

```
let GeoIPDB_FULL = _GetWatchlist("geoip");
SecurityEvent
| where EventID == 4625 and IPAddress != "<analyst-ip>"
| evaluate ipv4_lookup(GeoIPDB_FULL, IPAddress, network)
| summarize Attempts = count() by IPAddress, cityname, countryname
| order by Attempts desc
```

Files written or uploaded by attackers in Cowrie:

```
Cowrie_CL
| where eventid has_any ("file_upload", "file_download")
| extend sha256 = extract(@"([a-f0-9]{64})", 1, message)
| summarize Times = count(), First = min(TimeGenerated), Last =
max(TimeGenerated) by src_ip, sha256
```

Time each source spent inside Cowrie:

```

Cowrie_CL
| where eventid == "cowrie.session.closed"
| extend Seconds = todouble(extract(@"after ([0-9\\.]+) seconds", 1, message))
| summarize Sessions = count(), TotalMinutes = round(sum(Seconds) / 60, 1) by
src_ip
| order by TotalMinutes desc

```

Attempts per hour across RDP and SSH:

```

union
  (SecurityEvent | where EventID == 4625 | extend Source = "RDP"),
  (Cowrie_CL | where eventid startswith "cowrie.login" | extend Source =
"SSH")
| summarize Attempts = count() by Source, bin(TimeGenerated, 1h)
| render timechart

```

Sources

- [IBM: 2025 Cost of a Data Breach Report](#)
- [Bluefin: IBM 2025 report key findings](#)
- [Northdoor: Cost of a Data Breach 2025 key findings](#)
- [Qualora: BLS information security analyst pay](#)
- [The Register: Trend Micro on criminal service prices](#)
- [CyberSecureFox: Kaspersky botnet market research](#)
- [E. Thomason: Panchan miner delivered via fake sshd binary](#)
- [KlavanSec: 30-day exposed server study \(same Panchan hash\)](#)
- [MITRE ATT&CK Enterprise matrix](#)